

ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH
TRƯỜNG ĐẠI HỌC BÁCH KHOA



Mật mã và An ninh mạng (CO3069)

Báo Cáo Bài Tập Lớn

Xây dựng mô hình SOC sử dụng Wazuh để giám sát, phát hiện và phản ứng sự cố an ninh mạng

Sinh viên: Nguyễn Đức Nghĩa - 2312266 (*Lớp L01*)
Lê Quang Lợi - 2113976 (*Lớp L01*)
Tôn Trọng Tín - 2033338 (*Lớp L01*)

Tp.Hồ Chí Minh, Tháng 4/2026

Mục lục

1	Giới thiệu đề tài	4
1.1	Bối cảnh và lý do chọn đề tài	4
1.2	Mục tiêu dự án	4
1.3	Phạm vi và đối tượng nghiên cứu	4
2	Cơ sở lý thuyết	6
2.1	Mô hình P-P-T trong vận hành SOC	6
2.2	Khung NIST Incident Response	6
2.3	Công nghệ SIEM/XDR và giải pháp Wazuh	7
2.3.1	File Integrity Monitoring	7
2.3.2	Rootcheck	7
2.3.3	Vulnerability Detection	8
2.4	Ma trận MITRE ATT&CK	8
3	Phân tích và thiết kế hệ thống	9
3.1	Phân tích yêu cầu hệ thống	9
3.1.1	Các loại log cần thu thập	9
3.1.2	Các loại tấn công cần phát hiện	9
3.2	Thiết kế kiến trúc hệ thống (Topology)	10
3.2.1	Yêu cầu phần cứng	10
3.3	Thiết kế luồng dữ liệu (Log Flow)	10
3.4	Thiết kế kịch bản kiểm thử	11
3.4.1	Kịch bản 1: Brute Force Attack	11
3.4.2	Kịch bản 2: Malware / Persistence (FIM)	11
3.4.3	Kịch bản 3: Active Response	11
4	Hiện thực và đánh giá hệ thống	12
4.1	Triển khai hệ thống	12
4.1.1	Cấu hình quản lý tập trung trên Server	12
4.1.2	Cấu hình Agent	15
4.2	Thực thi kịch bản và kết quả	17
4.2.1	Kịch bản 1: Tấn công Brute Force (SSH/RDP)	17
4.2.2	Kịch bản 2: Phát hiện thay đổi file (FIM)	19
4.2.3	Kịch bản 3: Phản ứng tự động (Active Response)	21
4.2.4	Tổng hợp đánh giá kết quả	23
4.3	Đánh giá hệ thống	23
4.3.1	Phân tích chỉ số (Metrics)	23
4.3.2	Đánh giá thời gian đáp ứng (Detection Time)	24
4.3.3	Đánh giá tổng thể	24
5	Kết luận và hướng phát triển	25
5.1	Kết quả đạt được	25
5.2	Hạn chế	25
5.3	Hướng phát triển	26
6	Nguồn dữ liệu và nguồn code	27
6.1	Nguồn code và cấu hình	27
6.2	Vai trò của nguồn dữ liệu và nguồn code trong hệ thống	28



7 Tài liệu tham khảo

30



Danh sách thành viên và bảng phân công công việc

STT	Họ và tên	MSSV	Công việc	%
1	Nguyễn Đức Nghĩa	2312266	- Đề xuất giải pháp, kiểm thử hệ thống	100%
2	Lê Quang Lợi	2113976	- Viết báo cáo, tham gia kiểm thử	100%
3	Tôn Trọng Tín	2033338	- Viết báo cáo, tham gia kiểm thử	100%

Table 1: Danh sách thành viên và bảng phân công công việc

1 Giới thiệu đề tài

1.1 Bối cảnh và lý do chọn đề tài

Trong bối cảnh chuyển đổi số đang diễn ra mạnh mẽ, hệ thống công nghệ thông tin đóng vai trò quan trọng trong hoạt động của các doanh nghiệp, tổ chức và cơ quan. Các dịch vụ như hệ thống máy chủ, cơ sở dữ liệu, thư điện tử, ứng dụng nội bộ, hệ thống quản lý người dùng và các thiết bị đầu cuối đều tham gia trực tiếp vào quá trình vận hành. Tuy nhiên, cùng với sự mở rộng của hạ tầng công nghệ thông tin, nguy cơ mất an toàn thông tin cũng ngày càng gia tăng. Các hình thức tấn công mạng như dò quét dịch vụ, khai thác lỗ hổng, tấn công brute-force, mã độc, thay đổi trái phép tập tin hệ thống hoặc leo thang đặc quyền có thể gây ảnh hưởng nghiêm trọng đến tính bảo mật, toàn vẹn và tính sẵn sàng của hệ thống.

Trong phạm vi bài tập lớn này, đề tài tập trung tìm hiểu và triển khai một mô hình SOC thu nhỏ dựa trên giải pháp mã nguồn mở Wazuh. Wazuh là nền tảng bảo mật mã nguồn mở, kết hợp khả năng SIEM và XDR, hỗ trợ thu thập dữ liệu bảo mật từ endpoint, phát hiện mối đe dọa, phản ứng sự cố và hỗ trợ giám sát tuân thủ.¹ Việc lựa chọn Wazuh phù hợp với môi trường học tập và thực nghiệm vì có thể triển khai trong lab với chi phí thấp, hỗ trợ agent trên nhiều hệ điều hành và cung cấp sẵn nhiều chức năng phục vụ giám sát an ninh.

1.2 Mục tiêu dự án

Mục tiêu của dự án là xây dựng một mô hình SOC thu nhỏ nhằm phục vụ việc giám sát, phát hiện và phản ứng sự cố an ninh mạng trong môi trường lab. Mô hình được triển khai dựa trên nền tảng Wazuh, trong đó Wazuh Server đóng vai trò trung tâm thu thập, phân tích và quản lý cảnh báo; các máy Windows và Linux đóng vai trò endpoint được cài đặt Wazuh Agent để gửi log và sự kiện bảo mật về hệ thống trung tâm.

Cụ thể, dự án hướng đến các mục tiêu sau:

- Tìm hiểu khái niệm và vai trò của SOC trong hoạt động bảo đảm an toàn thông tin. Nội dung này giúp làm rõ vì sao doanh nghiệp cần một hệ thống giám sát tập trung thay vì chỉ dựa vào các công cụ bảo mật riêng lẻ.
- Triển khai được một hệ thống SOC cơ bản dựa trên mã nguồn mở, bao gồm máy chủ quản lý Wazuh, giao diện dashboard và các agent giám sát trên hệ điều hành Windows/Linux.
- Kiểm thử một số chức năng bảo mật cơ bản của Wazuh như thu thập log, phát hiện thay đổi tập tin, kiểm tra cấu hình hệ thống, phát hiện lỗ hổng và sinh cảnh báo khi có hành vi bất thường.
- Đánh giá khả năng hoạt động của mô hình SOC thu nhỏ thông qua các kịch bản thử nghiệm trong môi trường lab. Từ đó, rút ra nhận xét về ưu điểm, hạn chế và khả năng mở rộng của hệ thống khi áp dụng trong môi trường thực tế.

1.3 Phạm vi và đối tượng nghiên cứu

Phạm vi nghiên cứu của đề tài được giới hạn trong môi trường lab, không triển khai trên hệ thống doanh nghiệp thật. Mô hình được xây dựng với quy mô nhỏ, bao gồm một máy chủ Wazuh và một số máy agent sử dụng hệ điều hành Windows hoặc Linux. Các agent này đại diện cho các thiết bị đầu cuối hoặc máy chủ trong doanh nghiệp, có nhiệm vụ gửi log và sự kiện bảo mật về hệ thống trung tâm để phân tích.

¹<https://documentation.wazuh.com/current/getting-started/index.html>

Đối tượng nghiên cứu chính của đề tài bao gồm mô hình vận hành SOC, quy trình xử lý sự cố an ninh mạng, nền tảng SIEM/XDR Wazuh và một số chức năng giám sát endpoint. Trong đó, báo cáo tập trung vào các nội dung như giám sát log hệ thống, phát hiện thay đổi tập tin quan trọng, kiểm tra dấu hiệu bất thường, phát hiện lỗ hổng và ánh xạ cảnh báo với ma trận MITRE ATT&CK.

Do giới hạn về thời gian và điều kiện triển khai, đề tài không đi sâu vào các kỹ thuật tấn công nâng cao, không xây dựng hệ thống SOC quy mô lớn và không triển khai đầy đủ các thành phần như Threat Intelligence chuyên sâu, SOAR hoặc tích hợp nhiều nguồn log từ hệ thống mạng phức tạp. Các kịch bản thử nghiệm chủ yếu nhằm mục đích minh họa khả năng giám sát, phát hiện và cảnh báo của hệ thống trong phạm vi học tập.

2 Cơ sở lý thuyết

2.1 Mô hình P-P-T trong vận hành SOC

Mô hình P-P-T, viết tắt của People – Process – Technology, là một cách tiếp cận phổ biến trong quản lý và vận hành hệ thống an toàn thông tin. Đối với SOC, ba yếu tố con người, quy trình và công nghệ cần được kết hợp chặt chẽ để tạo thành một hệ thống giám sát và phản ứng sự cố hiệu quả.

Yếu tố **People** đề cập đến con người tham gia vào quá trình vận hành SOC. Trong doanh nghiệp, nhóm này có thể bao gồm chuyên viên giám sát cảnh báo, chuyên viên phân tích sự cố, quản trị viên hệ thống, quản trị viên mạng và người quản lý an toàn thông tin. Vai trò của con người là theo dõi cảnh báo, phân tích mức độ rủi ro, xác minh sự cố và đưa ra quyết định xử lý phù hợp. Một hệ thống có nhiều công cụ hiện đại nhưng thiếu người có kiến thức phân tích thì vẫn khó phát hiện chính xác các mối đe dọa.

Yếu tố **Process** đề cập đến các quy trình vận hành. SOC cần có quy trình rõ ràng để tiếp nhận cảnh báo, phân loại mức độ nghiêm trọng, điều tra nguyên nhân, cô lập hệ thống bị ảnh hưởng, khắc phục sự cố và ghi nhận bài học sau sự cố. Quy trình giúp hoạt động phản ứng sự cố diễn ra có tổ chức, tránh xử lý cảm tính hoặc bỏ sót các bước quan trọng.

Yếu tố **Technology** đề cập đến các công nghệ được sử dụng để hỗ trợ giám sát và phản ứng. Trong phạm vi đề tài này, Wazuh đóng vai trò là nền tảng công nghệ chính. Hệ thống hỗ trợ thu thập log từ endpoint, phân tích sự kiện bảo mật, phát hiện bất thường, sinh cảnh báo và cung cấp dashboard để người vận hành theo dõi. Ngoài ra, công nghệ còn có thể bao gồm máy chủ lưu trữ log, công cụ phân tích dữ liệu, hệ thống cảnh báo và các cơ chế phản ứng tự động.

Như vậy, SOC không chỉ đơn thuần là một phần mềm hoặc một hệ thống dashboard. SOC là sự kết hợp giữa con người, quy trình và công nghệ. Trong mô hình lab của bài tập lớn, yếu tố People được thể hiện qua người quản trị và phân tích cảnh báo; yếu tố Process được thể hiện qua quy trình giám sát, xác minh và phản ứng; còn yếu tố Technology được thể hiện qua nền tảng Wazuh và các agent Windows/Linux.

2.2 Khung NIST Incident Response

Incident Response là quá trình phát hiện, phân tích, xử lý và khôi phục sau các sự cố an ninh mạng. Trong lĩnh vực an toàn thông tin, NIST SP 800-61 là một tài liệu tham khảo quan trọng về xử lý sự cố máy tính. Tài liệu này đưa ra hướng dẫn cho quá trình phân tích dữ liệu liên quan đến sự cố và xác định phản ứng phù hợp, đồng thời có thể áp dụng độc lập với nền tảng phần cứng, hệ điều hành hoặc giao thức cụ thể.²

Trong phạm vi bài báo cáo này, quy trình xử lý sự cố được trình bày theo bốn giai đoạn chính:

- **Preparation – Chuẩn bị:** Đây là giai đoạn tổ chức chuẩn bị con người, quy trình, công cụ và tài nguyên cần thiết trước khi sự cố xảy ra. Trong mô hình lab, bước chuẩn bị bao gồm triển khai Wazuh Server, cài đặt agent, cấu hình thu thập log, thiết lập luật cảnh báo và xác định các kịch bản kiểm thử.
- **Detection and Analysis – Phát hiện và phân tích:** Đây là giai đoạn hệ thống giám sát thu thập dữ liệu, phát hiện dấu hiệu bất thường và sinh cảnh báo. Người phân tích cần kiểm tra nội dung cảnh báo, xác định nguồn phát sinh, đánh giá mức độ nghiêm trọng và phân biệt giữa cảnh báo thật với cảnh báo sai. Trong Wazuh, quá trình này được hỗ trợ thông qua dashboard, rule ID, mức độ cảnh báo, thông tin agent và dữ liệu log chi tiết.

²<https://csrc.nist.gov/pubs/sp/800/61/r2/final>

- **Containment, Eradication and Recovery – Cô lập, loại bỏ và khôi phục:** Khi sự cố được xác nhận, hệ thống hoặc người quản trị cần thực hiện các biện pháp giới hạn ảnh hưởng, loại bỏ nguyên nhân và đưa hệ thống trở lại trạng thái hoạt động bình thường. Ví dụ, nếu phát hiện một tài khoản có nhiều lần đăng nhập thất bại, người quản trị có thể kiểm tra nguồn truy cập, khóa tài khoản tạm thời hoặc cấu hình bổ sung cơ chế bảo vệ.
- **Post-Incident Activity – Hoạt động sau sự cố:** Sau khi sự cố được xử lý, tổ chức cần tổng hợp lại thông tin, đánh giá nguyên nhân, ghi nhận bài học kinh nghiệm và cải thiện cấu hình bảo mật. Đây là bước quan trọng giúp hệ thống ngày càng hoàn thiện hơn, giảm nguy cơ lặp lại sự cố trong tương lai.

Việc áp dụng khung NIST Incident Response giúp mô hình SOC trong bài tập lớn có quy trình xử lý rõ ràng, thay vì chỉ dừng lại ở việc hiển thị cảnh báo. Nhờ đó, hệ thống không chỉ có khả năng phát hiện mà còn hỗ trợ quá trình phân tích và phản ứng khi có sự kiện an ninh xảy ra.

2.3 Công nghệ SIEM/XDR và giải pháp Wazuh

SIEM, viết tắt của Security Information and Event Management, là công nghệ dùng để thu thập, tập trung, phân tích và quản lý các sự kiện an ninh từ nhiều nguồn khác nhau trong hệ thống. Một hệ thống SIEM thường nhận dữ liệu từ máy chủ, thiết bị mạng, ứng dụng, hệ điều hành và endpoint, sau đó thực hiện phân tích tương quan để phát hiện các dấu hiệu bất thường.

XDR, viết tắt của Extended Detection and Response, mở rộng khả năng phát hiện và phản ứng trên nhiều lớp bảo mật khác nhau, đặc biệt là endpoint, máy chủ, cloud và các nguồn dữ liệu liên quan. So với cách giám sát truyền thống, XDR tập trung nhiều hơn vào việc kết hợp dữ liệu từ nhiều nguồn để phát hiện mối đe dọa và hỗ trợ phản ứng nhanh hơn.

Wazuh là một nền tảng mã nguồn mở kết hợp khả năng SIEM và XDR. Theo tài liệu chính thức, Wazuh có thể bảo vệ workload trong môi trường on-premises, ảo hóa, container và cloud, đồng thời hỗ trợ phát hiện mối đe dọa, phản ứng sự cố và giám sát tuân thủ. Trong mô hình bài tập lớn, Wazuh được lựa chọn vì phù hợp với môi trường lab, có thể triển khai miễn phí, hỗ trợ agent trên nhiều hệ điều hành và cung cấp sẵn nhiều chức năng phục vụ giám sát endpoint.

2.3.1 File Integrity Monitoring

FIM, hay File Integrity Monitoring, là chức năng giám sát tính toàn vẹn của tập tin. FIM giúp theo dõi các thay đổi trên tập tin hệ thống, tập tin ứng dụng hoặc thư mục quan trọng. Khi một tập tin bị tạo mới, chỉnh sửa hoặc xóa, hệ thống có thể sinh cảnh báo để người quản trị kiểm tra. Theo tài liệu Wazuh, FIM giúp phát hiện thay đổi trên các tập tin quan trọng, từ đó giảm nguy cơ dữ liệu bị đánh cắp hoặc bị can thiệp trái phép.³

Trong mô hình SOC thu nhỏ, FIM có thể được sử dụng để giám sát các thư mục hoặc tập tin nhạy cảm trên agent. Ví dụ, trên Linux có thể giám sát các tập tin cấu hình trong thư mục `/etc`, còn trên Windows có thể giám sát một thư mục chứa tập tin cấu hình hoặc tập tin hệ thống quan trọng. Khi có thay đổi bất thường, Wazuh sẽ ghi nhận sự kiện và hiển thị cảnh báo trên dashboard.

2.3.2 Rootcheck

Rootcheck là chức năng dùng để phát hiện các dấu hiệu bất thường có thể liên quan đến malware hoặc rootkit trên endpoint. Wazuh sử dụng Rootcheck để giám sát các thư mục, registry,

³<https://documentation.wazuh.com/current/user-manual/capabilities/file-integrity/index.html>

system call hoặc dấu hiệu bất thường khác, từ đó sinh cảnh báo khi phát hiện hành vi đáng nghi.⁴ Trong môi trường lab, chức năng này giúp minh họa khả năng kiểm tra trạng thái bảo mật của endpoint.

Rootcheck không thay thế hoàn toàn cho phần mềm diệt mã độc chuyên dụng, nhưng đóng vai trò quan trọng trong việc hỗ trợ SOC phát hiện những dấu hiệu bất thường ở mức hệ thống. Khi kết hợp Rootcheck với các nguồn log khác, người quản trị có thể có cái nhìn đầy đủ hơn về trạng thái bảo mật của endpoint.

2.3.3 Vulnerability Detection

Vulnerability Detection là chức năng phát hiện lỗ hổng trên hệ thống được giám sát. Wazuh sử dụng dữ liệu về phần mềm, gói cài đặt và nguồn thông tin lỗ hổng để xác định các điểm yếu bảo mật tồn tại trên endpoint. Theo tài liệu Wazuh, chức năng này được hỗ trợ bởi Wazuh CTI và có thể được truy cập thông qua module Vulnerability Detection trên dashboard.⁵

Đây là chức năng quan trọng giúp người quản trị biết hệ thống nào đang tồn tại lỗ hổng cần cập nhật hoặc xử lý. Trong môi trường doanh nghiệp, việc phát hiện lỗ hổng giúp giảm nguy cơ bị khai thác bởi các cuộc tấn công đã biết. Trong phạm vi bài tập lớn, Vulnerability Detection được sử dụng để minh họa khả năng đánh giá trạng thái an toàn của các agent Windows/Linux trong mô hình SOC thu nhỏ.

Nhìn chung, Wazuh là giải pháp phù hợp cho đề tài vì đáp ứng được các yêu cầu cơ bản của một mô hình SOC thu nhỏ: thu thập log, giám sát endpoint, phát hiện bất thường, cảnh báo sự kiện và hỗ trợ đánh giá trạng thái bảo mật của hệ thống.

2.4 Ma trận MITRE ATT&CK

MITRE ATT&CK là một cơ sở tri thức về chiến thuật và kỹ thuật tấn công của đối thủ, được xây dựng dựa trên các quan sát thực tế. MITRE ATT&CK được sử dụng rộng rãi để mô tả hành vi tấn công, xây dựng mô hình mối đe dọa và hỗ trợ phát triển phương pháp phát hiện trong lĩnh vực an ninh mạng.⁶

Trong MITRE ATT&CK, tactic thể hiện mục tiêu chiến thuật của kẻ tấn công, tức lý do vì sao một hành động được thực hiện. Ví dụ, kẻ tấn công có thể muốn truy cập ban đầu, duy trì sự tồn tại, leo thang đặc quyền, né tránh phòng thủ hoặc thu thập dữ liệu. Technique thể hiện cách thức cụ thể mà kẻ tấn công sử dụng để đạt được mục tiêu đó. MITRE định nghĩa tactic là phần thể hiện mục tiêu chiến thuật đứng sau một kỹ thuật hoặc tiểu kỹ thuật.⁷

Trong mô hình SOC, MITRE ATT&CK giúp chuẩn hóa cách mô tả cảnh báo và sự kiện bảo mật. Thay vì chỉ ghi nhận một cảnh báo đơn lẻ, hệ thống có thể ánh xạ cảnh báo đó với một kỹ thuật tấn công cụ thể. Ví dụ, nhiều lần đăng nhập thất bại có thể liên quan đến hành vi dò đoán mật khẩu; thay đổi bất thường trong tập tin cấu hình có thể liên quan đến hành vi duy trì truy cập hoặc thay đổi cấu hình hệ thống; thay đổi registry trên Windows có thể liên quan đến cơ chế persistence.

⁴<https://documentation.wazuh.com/current/user-manual/capabilities/malware-detection/rootkits-behavior-detection.html>

⁵<https://documentation.wazuh.com/current/user-manual/capabilities/vulnerability-detection/how-it-works.html>

⁶<https://attack.mitre.org/>

⁷<https://attack.mitre.org/tactics/>

3 Phân tích và thiết kế hệ thống

3.1 Phân tích yêu cầu hệ thống

Hệ thống được xây dựng nhằm mục tiêu giám sát an ninh tập trung theo mô hình SOC (Security Operations Center), với khả năng thu thập, phân tích và phát hiện các hành vi tấn công trên host với nền tảng chính được sử dụng là Wazuh.

3.1.1 Các loại log cần thu thập

Để đảm bảo khả năng giám sát toàn diện, hệ thống cần thu thập nhiều loại log khác nhau từ các agent bao gồm:

- **Log xác thực (Authentication logs):**
Bao gồm các sự kiện đăng nhập thành công/thất bại từ SSH (Linux) hoặc RDP (Windows). Đây là nguồn dữ liệu quan trọng để phát hiện các cuộc tấn công brute force.
- **Log hệ thống (System logs):**
Bao gồm các log từ syslog, kern.log, dpkg.log, giúp theo dõi hoạt động của hệ điều hành và các thay đổi liên quan đến phần mềm.
- **Log giám sát file (FIM logs):**
Ghi nhận các thay đổi trong file hệ thống, đặc biệt là các file quan trọng như /etc/passwd, giúp phát hiện hành vi persistence hoặc leo thang đặc quyền.
- **Log tiến trình và mạng:**
Thu thập thông tin từ các lệnh như netstat, df, last, giúp cung cấp cái nhìn tổng thể về trạng thái hệ thống.
- **Log lỗ hổng bảo mật (Vulnerability logs):**
Dữ liệu từ module Vulnerability Detector giúp phát hiện các CVE tồn tại trên hệ thống.

3.1.2 Các loại tấn công cần phát hiện

Dựa trên mục tiêu xây dựng một hệ thống SOC cơ bản, các kịch bản tấn công được lựa chọn bao gồm:

- **Tấn công Brute Force (T1110):**
Phát hiện các hành vi đăng nhập thất bại liên tiếp trong thời gian ngắn.
- **Tấn công thay đổi hệ thống (Persistence / Privilege Escalation):**
Phát hiện thay đổi file hệ thống quan trọng thông qua FIM.
- **Hành vi bất thường cần phản ứng tự động:**
Ví dụ như brute force sẽ kích hoạt cơ chế chặn IP (Active Response).

Việc lựa chọn các kịch bản này giúp kiểm tra đầy đủ khả năng của hệ thống ở cả ba giai đoạn: phát hiện, phân tích và phản ứng.

3.2 Thiết kế kiến trúc hệ thống (Topology)

Sơ đồ mạng tổng thể

Hệ thống được triển khai trong môi trường lab với các thành phần chính:

- **Wazuh Server (Manager - Windows):**
Trung tâm xử lý log và sinh alert.
- **Agent (Linux):**
Thu thập log từ hệ thống và gửi về server.
- **Kali Linux:**
Đóng vai trò máy tấn công để thực hiện các kịch bản kiểm thử.

Mô hình tổng thể:

Kali Linux → Target (Agent) → Wazuh Agent → Wazuh Server → Dashboard

3.2.1 Yêu cầu phần cứng

Hệ thống được triển khai trên môi trường ảo hóa với cấu hình đề xuất như sau:

Thành phần	CPU	RAM	Hệ điều hành
Wazuh Server	2 core	4–8 GB	Ubuntu Server
Agent Linux	1–2 core	2 GB	Ubuntu
Agent Windows	2 core	4 GB	Windows 10/11
Kali Linux	2 core	2–4 GB	Kali Linux

Cấu hình này đảm bảo hệ thống hoạt động ổn định trong môi trường thử nghiệm.

3.3 Thiết kế luồng dữ liệu (Log Flow)

Hệ thống được thiết kế theo mô hình thu thập và phân tích tập trung. Luồng dữ liệu được mô tả như sau:

Agent → Thu thập log → Mã hóa → Wazuh Server → Phân tích → Alert → Dashboard

Chi tiết quá trình:

1. **Thu thập log:**
Agent thu thập log từ hệ thống
2. **Mã hóa và truyền dữ liệu:**
Log được mã hóa (AES/TLS) và gửi về server thông qua giao thức TCP.
3. **Giải mã và phân tích:**
Wazuh Server thực hiện:
 - Decoding log
 - So khớp rule
 - Phát hiện bất thường
4. **Sinh cảnh báo (Alert):**
Nếu phát hiện hành vi đáng ngờ, hệ thống sinh alert với mức độ severity.

5. **Hiển thị:**

Alert được hiển thị trên dashboard phục vụ phân tích.

Luồng này đảm bảo khả năng phát hiện gần realtime và hỗ trợ phân tích tập trung.

3.4 **Thiết kế kịch bản kiểm thử**

3.4.1 **Kịch bản 1: Brute Force Attack**

- **Mô tả:**

Attacker sử dụng công cụ brute force để đăng nhập SSH/RDP.

- **Logic phát hiện:**

- Nhiều lần đăng nhập thất bại
- Pattern bất thường trong thời gian ngắn
→ Trigger rule brute force

- **Kết quả mong đợi:**

Alert level cao + mapping MITRE T1110

3.4.2 **Kịch bản 2: Malware / Persistence (FIM)**

- **Mô tả:**

Thay đổi file hệ thống như /etc/passwd.

- **Logic phát hiện:**

- Thay đổi checksum
- So sánh diff
→ Trigger FIM alert

- **Kết quả mong đợi:**

Phát hiện thay đổi + hiển thị nội dung diff

3.4.3 **Kịch bản 3: Active Response**

- **Mô tả:**

Sau khi phát hiện brute force, hệ thống chặn IP attacker.

- **Logic:**

- Rule match
- Trigger active response
- Thực thi firewall-drop

- **Kết quả mong đợi:**

IP bị chặn qua iptables

4 Hiện thực và đánh giá hệ thống

4.1 Triển khai hệ thống

4.1.1 Cấu hình quản lý tập trung trên Server

Trong mô hình hệ thống giám sát an ninh, máy chủ trung tâm sử dụng nền tảng Wazuh Manager đóng vai trò thu thập, phân tích và xử lý toàn bộ log được gửi từ các agent. File cấu hình chính của server được đặt tại đường dẫn `single-node/config/wazuh_cluster/wazuh_manager.conf`, nơi định nghĩa toàn bộ hành vi của hệ thống.

Trước hết, hệ thống được cấu hình để hỗ trợ cơ chế đăng ký agent động thông qua module `<auth>`. Dịch vụ này được kích hoạt trên cổng 1515 và cho phép xác thực agent dựa trên địa chỉ IP nguồn. Cơ chế này giúp đảm bảo rằng chỉ những agent hợp lệ mới có thể tham gia vào hệ thống, đồng thời tăng cường khả năng kiểm soát truy cập trong môi trường mạng nội bộ.

```
<auth>
  <disabled>no</disabled>
  <port>1515</port>
  <use_source_ip>yes</use_source_ip>
</auth>
```

Tiếp theo, các thiết lập toàn cục (global settings) được tối ưu nhằm phục vụ cho việc phân tích và lưu trữ dữ liệu. Hệ thống được cấu hình để xuất log dưới dạng JSON, một định dạng phổ biến giúp dễ dàng tích hợp với các hệ thống phân tích log khác như ELK Stack. Đồng thời, chỉ các sự kiện quan trọng (alerts) mới được ghi log thay vì toàn bộ dữ liệu, giúp giảm thiểu dung lượng lưu trữ và tăng hiệu suất xử lý. Ngoài ra, server cũng được thiết lập để phát hiện agent mất kết nối nếu không có tín hiệu trong vòng 10 phút, từ đó hỗ trợ quản trị viên nhanh chóng phát hiện các sự cố liên quan đến hệ thống.

```
<!-- Global settings: control overall behavior of Wazuh manager -->
<global>
  <!-- Enable JSON formatted output for alerts (useful for integrations like ELK) -->
  <jsonout_output>yes</jsonout_output>

  <!-- Enable logging of alerts -->
  <alerts_log>yes</alerts_log>

  <!-- Disable full logging of all events (only alerts will be logged) -->
  <logall>no</logall>

  <!-- Time before an agent is considered disconnected -->
  <agents_disconnection_time>10m</agents_disconnection_time>

  <!-- Whitelisted IP addresses or hostnames (ignored by some rules) -->
  <white_list>127.0.0.1</white_list>
  <white_list>^localhost.localdomain$</white_list>
</global>
```

Một thành phần quan trọng khác là module phát hiện lỗ hổng (Vulnerability Detector). Module này được kích hoạt và cấu hình để quét hệ thống định kỳ mỗi 5 phút, sử dụng dữ liệu từ hai nguồn chính là Canonical (dành cho Ubuntu) và NVD (National Vulnerability Database). Nhờ đó, hệ thống có khả năng phát hiện các lỗ hổng bảo mật (CVE) gần như theo thời gian thực, giúp nâng cao khả năng phòng thủ trước các mối đe dọa đã biết.

```
<!-- Vulnerability detector module: scans system for known CVEs -->
<vulnerability-detector>
  <!-- Enable vulnerability detection -->
  <enabled>yes</enabled>

  <!-- Interval between scans -->
  <interval>5m</interval>

  <!-- Run scan immediately when service starts -->
  <run_on_start>yes</run_on_start>

  <!-- Canonical provider (Ubuntu security advisories) -->
  <provider name="canonical">
    <enabled>yes</enabled>

    <!-- Target operating system versions -->
    <os>focal</os>
    <os>jammy</os>

    <!-- Interval to update vulnerability database -->
    <update_interval>1h</update_interval>
  </provider>

  <!-- NVD (National Vulnerability Database) provider -->
  <provider name="nvd">
    <enabled>yes</enabled>

    <!-- Update interval for NVD feeds -->
    <update_interval>1h</update_interval>
  </provider>
</vulnerability-detector>
```

Đối với việc giám sát tính toàn vẹn của hệ thống, module File Integrity Monitoring (FIM) được triển khai thông qua cấu hình <syscheck>. Hệ thống thực hiện quét định kỳ mỗi 12 giờ, đồng thời kích hoạt chế độ giám sát thời gian thực đối với các thư mục quan trọng như /etc, /usr/bin và /usr/sbin. Điều này cho phép phát hiện ngay lập tức các thay đổi bất thường trong file hệ thống, chẳng hạn như việc chỉnh sửa file cấu hình hoặc thay thế binary. Các file không cần thiết như file log hoặc file tạm được loại trừ nhằm giảm thiểu nhiễu và tối ưu hiệu suất.

```
<!-- File Integrity Monitoring (FIM) configuration -->
<syscheck>
  <!-- Enable syscheck module -->
  <disabled>no</disabled>

  <!-- Frequency of full scans (in seconds: 43200 = 12 hours) -->
  <frequency>43200</frequency>

  <!-- Run a scan at startup -->
  <scan_on_start>yes</scan_on_start>

  <!-- Alert when new files are detected -->
  <alert_new_files>yes</alert_new_files>
```

```
<!-- Directories to monitor in real-time with full attribute checking -->
<directories realtime="yes" report_changes="yes" check_all="yes">
  /etc,/usr/bin,/usr/sbin
</directories>

<!-- Additional critical system directories -->
<directories realtime="yes" check_all="yes">
  /bin,/sbin,/boot
</directories>

<!-- Ignore specific files from monitoring -->
<ignore>/etc/mtab</ignore>
<ignore>/etc/hosts.deny</ignore>

<!-- Ignore files matching regex patterns (e.g., logs, swap files) -->
<ignore type="sregex">.log$|.swp$</ignore>

<!-- Synchronization settings (for cluster environments) -->
<synchronization>
  <!-- Enable syscheck synchronization between nodes -->
  <enabled>yes</enabled>

  <!-- Sync interval -->
  <interval>5m</interval>
</synchronization>
</syscheck>
```

Bên cạnh khả năng phát hiện, hệ thống còn được trang bị cơ chế phản ứng tự động (Active Response). Khi một sự kiện nguy hiểm được phát hiện, ví dụ như tấn công brute force, hệ thống sẽ kích hoạt lệnh firewall-drop để chặn địa chỉ IP của attacker ngay tại máy agent. Quá trình này diễn ra hoàn toàn tự động và có thời hạn cụ thể (60 giây), giúp giảm thiểu tác động của tấn công mà không cần can thiệp thủ công từ quản trị viên.

```
<!-- Command definition for active response -->
<command>
  <!-- Name of the command -->
  <name>firewall-drop</name>

  <!-- Executable script or binary -->
  <executable>firewall-drop</executable>

  <!-- Allow command to run with timeout -->
  <timeout_allowed>yes</timeout_allowed>
</command>

<!-- Active response configuration: automated actions on detected threats -->
<active-response>
  <!-- Command to execute -->
  <command>firewall-drop</command>

  <!-- Where to execute the command (local machine) -->
  <location>local</location>

  <!-- Rule IDs that trigger this response -->
```

```
<rules_id>5712,5763</rules_id>

<!-- Duration of the action (e.g., block IP for 60 seconds) -->
<timeout>60</timeout>
</active-response>
```

Ngoài ra, hệ thống cũng được cấu hình để sử dụng cả bộ rule mặc định và rule tùy chỉnh. Điều này cho phép mở rộng khả năng phát hiện theo các kịch bản riêng biệt của từng môi trường triển khai. Cuối cùng, kết nối giữa agent và server được thiết lập thông qua giao thức TCP trên cổng 1514 với chế độ bảo mật (secure), đảm bảo dữ liệu log được truyền đi một cách an toàn và đáng tin cậy.

```
<!-- Ruleset configuration: defines where rules and decoders are loaded from -->
<ruleset>
  <!-- Default decoders directory -->
  <decoder_dir>ruleset/decoders</decoder_dir>

  <!-- Default rules directory -->
  <rule_dir>ruleset/rules</rule_dir>

  <!-- Custom rules directory -->
  <rule_dir>etc/rules</rule_dir>

  <!-- Custom decoders directory -->
  <decoder_dir>etc/decoders</decoder_dir>
</ruleset>

<!-- Remote configuration: defines how agents connect to manager -->
<remote>
  <!-- Secure connection (TLS/SSL) -->
  <connection>secure</connection>

  <!-- Port used for agent communication -->
  <port>1514</port>

  <!-- Communication protocol -->
  <protocol>tcp</protocol>
</remote>
```

4.1.2 Cấu hình Agent

Các agent được triển khai trên các máy mục tiêu (Linux/Windows) với nhiệm vụ thu thập log và gửi về server để phân tích. Trong trường hợp này, agent được cấu hình để kết nối trực tiếp đến server tại địa chỉ IP 192.168.1.6 (IP của host) thông qua cổng 1514 bằng giao thức TCP, đảm bảo tính ổn định trong quá trình truyền dữ liệu.

Một điểm đáng chú ý là agent được cấu hình hỗ trợ cơ chế tự động đăng ký (enrollment). Khi khởi động, agent sẽ sử dụng file xác thực để đăng ký với server mà không cần thao tác thủ công. Điều này giúp đơn giản hóa quá trình triển khai trong môi trường có nhiều máy. Ngoài ra, agent còn được cấu hình buffer để đảm bảo khả năng xử lý log ổn định ngay cả khi lưu lượng log tăng cao.

```
<client>
```



```
<server>
  <address>192.168.1.6</address>
  <port>1514</port>
  <protocol>tcp</protocol>
</server>
<config-profile>ubuntu, ubuntu24, ubuntu24.04</config-profile>
<notify_time>10</notify_time>
<time-reconnect>60</time-reconnect>
<auto_restart>yes</auto_restart>
<crypto_method>aes</crypto_method>
<enrollment>
  <enabled>yes</enabled>
  <agent_name>Physical</agent_name>
  <authorization_pass_path>etc/authd.pass</authorization_pass_path>
</enrollment>
</client>
<client_buffer>
  <!-- Agent buffer options -->
  <disabled>no</disabled>
  <queue_size>5000</queue_size>
  <events_per_second>500</events_per_second>
</client_buffer>
```

Về mặt bảo mật, agent được tích hợp module Rootcheck nhằm phát hiện các dấu hiệu của rootkit, trojan hoặc các hành vi bất thường trong hệ thống. Module này thực hiện kiểm tra định kỳ mỗi 12 giờ, bao gồm việc kiểm tra file hệ thống, tiến trình, cổng mạng và các dấu hiệu xâm nhập phổ biến.

```
<!-- Policy monitoring -->
<rootcheck>
  <disabled>no</disabled>
  <check_files>yes</check_files>
  <check_trojans>yes</check_trojans>
  <check_dev>yes</check_dev>
  <check_sys>yes</check_sys>
  <check_pids>yes</check_pids>
  <check_ports>yes</check_ports>
  <check_if>yes</check_if>

  <!-- Frequency that rootcheck is executed - every 12 hours -->
  <frequency>43200</frequency>

  <rootkit_files>etc/shared/rootkit_files.txt</rootkit_files>
  <rootkit_trojans>etc/shared/rootkit_trojans.txt</rootkit_trojans>

  <skip_nfs>yes</skip_nfs>
</rootcheck>
```

Ngoài ra, module Syscollector được kích hoạt để thu thập thông tin hệ thống, bao gồm phần cứng, hệ điều hành, danh sách phần mềm, các cổng mạng đang mở và các tiến trình đang chạy. Dữ liệu này đóng vai trò quan trọng trong việc xây dựng inventory hệ thống và hỗ trợ cho quá trình phát hiện lỗ hổng.

```
<!-- System inventory -->
```

```
<wodle name="syscollector">
  <disabled>no</disabled>
  <interval>1h</interval>
  <scan_on_start>yes</scan_on_start>
  <hardware>yes</hardware>
  <os>yes</os>
  <network>yes</network>
  <packages>yes</packages>
  <ports all="no">yes</ports>
  <processes>yes</processes>

  <!-- Database synchronization settings -->
  <synchronization>
    <max_eps>10</max_eps>
  </synchronization>
</wodle>
```

Hệ thống cũng triển khai cơ chế đánh giá cấu hình bảo mật thông qua module SCA (Security Configuration Assessment). Module này cho phép so sánh cấu hình hiện tại của hệ thống với các tiêu chuẩn bảo mật, từ đó phát hiện các cấu hình yếu hoặc không tuân thủ best practice.

```
<sca>
  <enabled>yes</enabled>
  <scan_on_start>yes</scan_on_start>
  <interval>12h</interval>
  <skip_nfs>yes</skip_nfs>
</sca>
```

4.2 Thực thi kịch bản và kết quả

Trong phần này, hệ thống được kiểm thử thông qua ba kịch bản tấn công tiêu biểu nhằm đánh giá toàn diện khả năng phát hiện và phản ứng của hệ thống giám sát an ninh. Các kịch bản bao gồm tấn công brute force, thay đổi file hệ thống và cơ chế phản ứng tự động.

4.2.1 Kịch bản 1: Tấn công Brute Force (SSH/RDP)

Mô tả kịch bản:

Trong kịch bản này, máy Kali Linux được sử dụng để thực hiện tấn công brute force vào dịch vụ SSH (Linux) hoặc RDP (Windows). Công cụ Hydra được sử dụng để gửi liên tục các yêu cầu đăng nhập với nhiều tổ hợp username/password khác nhau.

Mục tiêu của kịch bản là kiểm tra khả năng phát hiện hành vi đăng nhập thất bại lặp lại – một dấu hiệu điển hình của tấn công brute force.

Phân tích hoạt động hệ thống:

Khi cuộc tấn công diễn ra, các log đăng nhập thất bại được ghi nhận tại agent (ví dụ: /var/log/auth.log trên Linux). Agent thu thập và gửi các log này về server.

Tại server, Wazuh thực hiện:

- Giải mã log (decoding)
- So khớp với các rule có sẵn
- Phát hiện pattern đăng nhập thất bại liên tiếp



Khi vượt qua ngưỡng xác định, hệ thống sinh cảnh báo với mức độ nghiêm trọng cao.

Cách thức hiện thực:

Trên Kali Linux, sử dụng công cụ Hydra:

```
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://{[{}]\_MY\_WINDOWS{}} -t 4 -V
```

Giải thích:

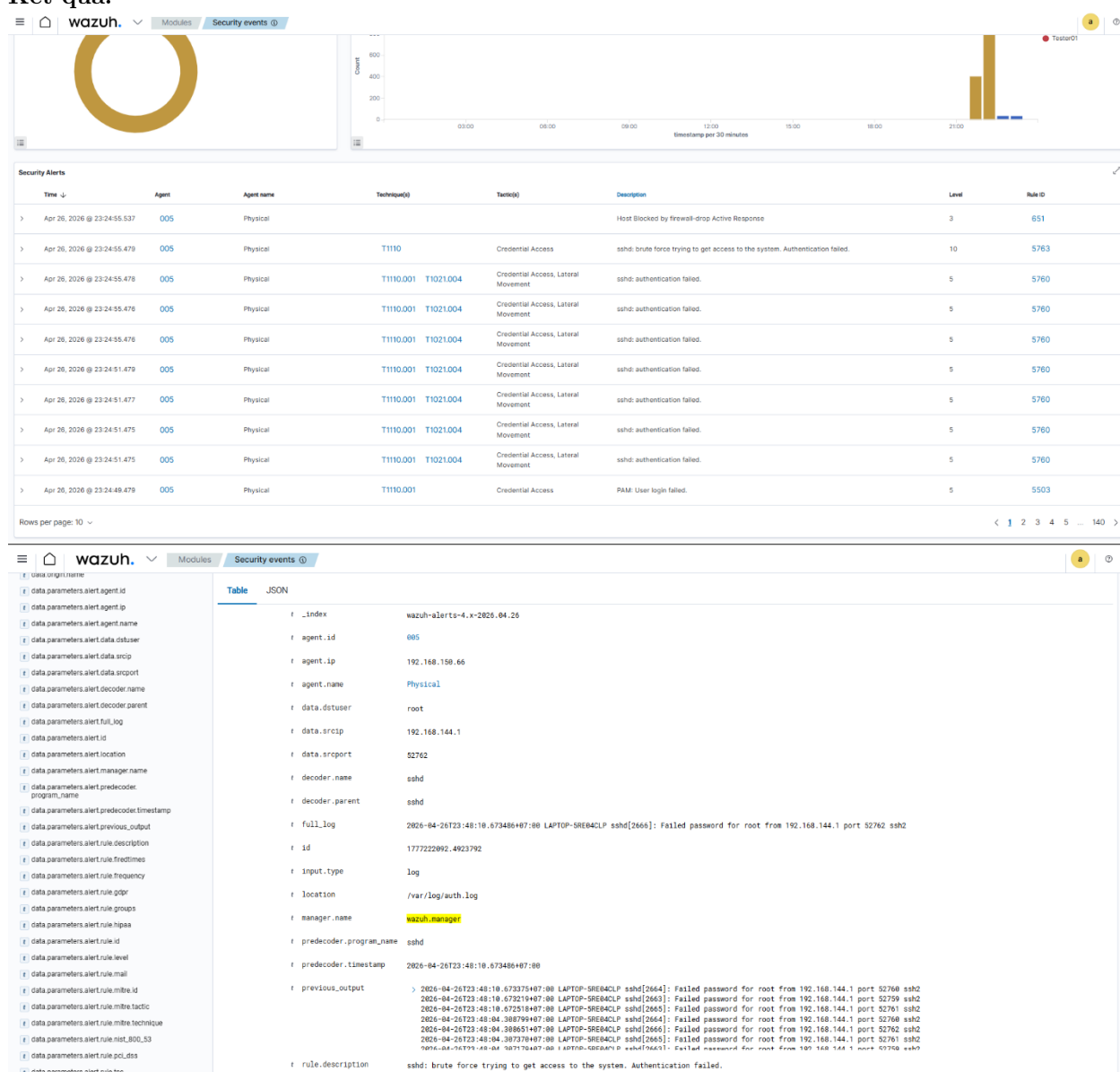
-l root: tài khoản mục tiêu

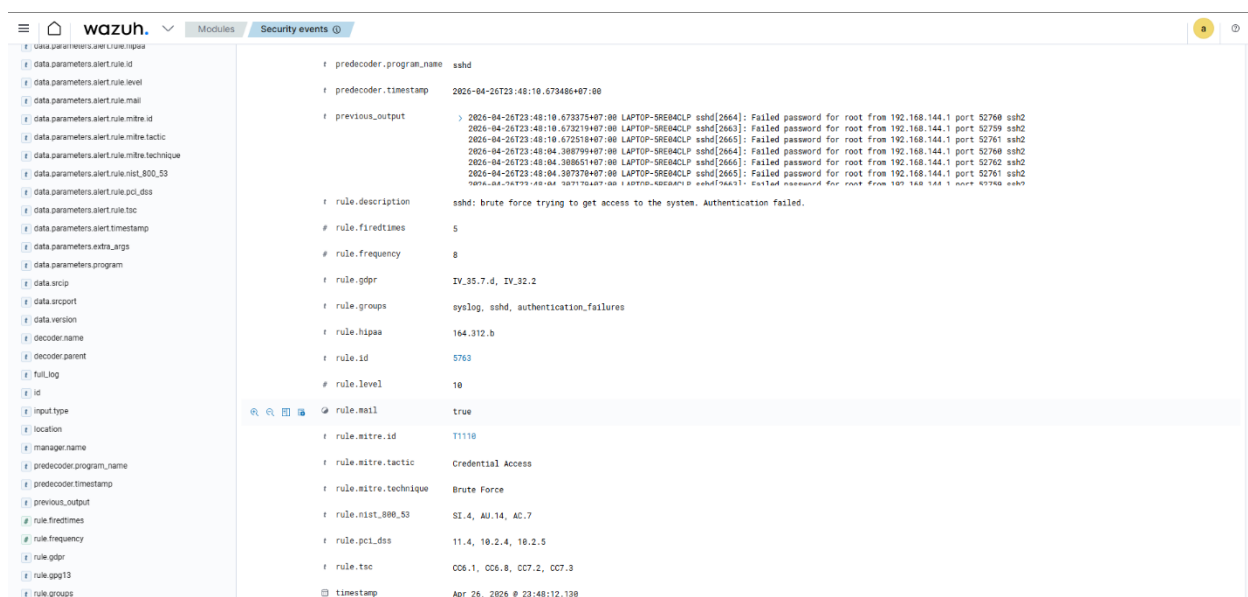
-P: danh sách password

-t 4: số luồng tấn công song song

-V: hiển thị chi tiết quá trình

Kết quả:





The screenshot shows the Wazuh Security events interface. On the left, a sidebar lists various alert parameters. The main panel displays the details for rule ID 5763, which is a brute force detection rule for SSH. The rule is named 'ssh: brute force trying to get access to the system. Authentication failed.' and has a level of 10. It is triggered by the 'rule.mail' parameter being set to 'true'. The rule is associated with the MITRE tactic 'Credential Access' and the technique 'Brute Force'. The rule is also associated with the NIST 800-53 standard 'SI.4, AU.14, AC.7' and the PCI DSS standard '11.4, 10.2.4, 10.2.5'. The rule is triggered by the 'rule.tsc' parameter being set to 'CC6.1, CC6.8, CC7.2, CC7.3'. The rule is triggered by the 'rule.gpg13' parameter being set to 'Apr 26, 2024 @ 23:48:12.130'.

Hệ thống phát hiện thành công với:

- Alert level: 10 (mức độ nghiêm trọng cao)
- Hiển thị:
 - Địa chỉ IP attacker: 192.168.144.1
 - Tài khoản bị tấn công: root
 - Số lần đăng nhập thất bại: 5 (dựa trên chuỗi log trong previous_output)

Alert được ánh xạ theo MITRE ATT&CK:

- Technique ID: T1110 – Brute Force

Đánh giá:

Hệ thống có khả năng phát hiện nhanh và chính xác hành vi brute force. Các rule mặc định của Wazuh hoạt động hiệu quả mà không cần tùy chỉnh thêm.

4.2.2 Kịch bản 2: Phát hiện thay đổi file (FIM)

Mô tả kịch bản:

Một file hệ thống quan trọng (ví dụ: /etc/passwd) được chỉnh sửa để mô phỏng các hành vi tấn công như:

- Tạo user trái phép
- Thay đổi quyền truy cập
- Chèn backdoor

Phân tích hoạt động hệ thống:

Agent giám sát file ở chế độ realtime. Khi có thay đổi:

- Tính lại checksum
- So sánh với giá trị trước đó
- Phát hiện sự khác biệt
- Gửi log về server

Server tiến hành phân tích và sinh cảnh báo tương ứng.

Cách thức hiện thực:

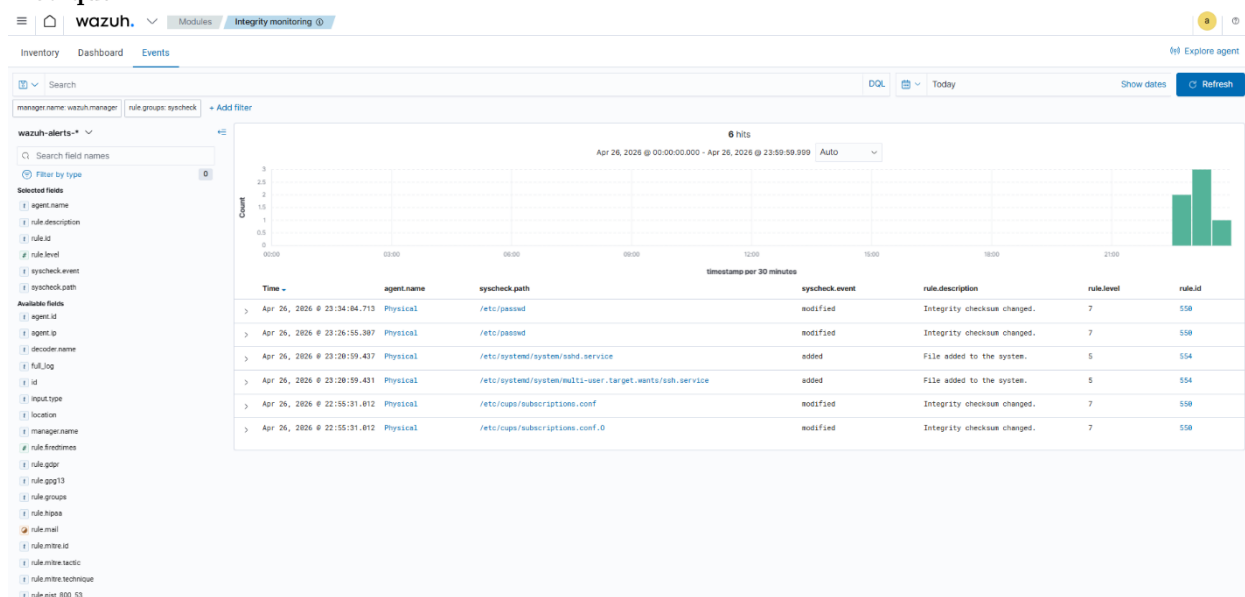
Trên Ubuntu (WSL2), thực hiện chỉnh sửa file hệ thống:

```
sudo echo \"1133nghia_soc_analyst:x:0:0::/root:/bin/bash\" \\| sudo tee -a /etc/passwd
```

Phân tích hành vi:

- Thêm user có **UID = 0 (root)**
- Đây là hành vi **Privilege Escalation + Persistence** cực kỳ nguy hiểm

Kết quả:



wazuh - Modules Integrity monitoring	
rule.mitre.technique	Stored Data Manipulation
rule.nist_800_53	SI.7
rule.pci_dss	11.5
rule.tsc	PT1.4, PT1.5, CC6.1, CC6.8, CC7.2, CC7.3
syscheck.diff	size, mtime, md5, sha1, sha256
syscheck.diff	46047 > 1133nghia_soc_analyst.x@8::root::bin/bash
syscheck.event	modified
syscheck.gid_after	0
syscheck.gname_after	root
syscheck.inode_after	225742
syscheck.md5_after	8434d4577f8e9f8967e88d5c8c108e32
syscheck.md5_before	073e8d9311399553b248e8f5ab50f4f
syscheck.mode	realtime
syscheck.mtime_after	Apr 26, 2026 @ 23:34:04.000
syscheck.mtime_before	Apr 26, 2026 @ 23:26:55.000
syscheck.path	/etc/passwd
syscheck.perm_after	rw-r--r--
syscheck.sha1_after	105af27ab2feaf68fb7b568bb1dc49ea43fae7e
syscheck.sha1_before	16d2fbf8dc3193c956e2362acca567b4dd5b6b09
syscheck.sha256_after	0003f122b77d74e152d788cc332745674ab1d98577bdcfa9b0ed0147454878bc
syscheck.sha256_before	1da36cd8e1816dc0032971819d580d8d714748f4e2627c2d37b1404e0866a7f38

Hệ thống phát hiện ngay lập tức với các thông tin:

- Đường dẫn file: /etc/passwd
- Thời gian thay đổi: 26/4/2026, 23:34:04
- Giá trị hash trước và sau đã thay đổi
- Loại thay đổi: modified

Ngoài ra, hệ thống cung cấp thông tin diff giúp xác định chính xác nội dung bị thay đổi.

Đánh giá:

FIM hoạt động hiệu quả, đặc biệt trong chế độ realtime. Đây là cơ chế quan trọng giúp phát hiện các hành vi persistence và leo thang đặc quyền.

4.2.3 Kịch bản 3: Phản ứng tự động (Active Response)

Mô tả kịch bản:

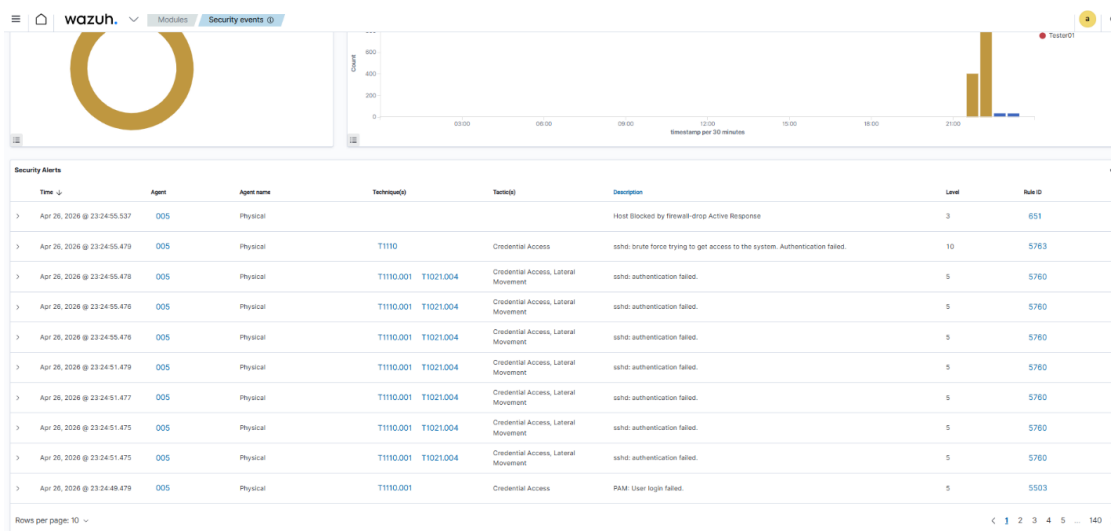
Khi phát hiện tấn công brute force, hệ thống kích hoạt cơ chế phản ứng tự động để chặn IP attacker.

Phân tích hoạt động hệ thống:

Quy trình diễn ra như sau:

- Rule brute force được kích hoạt
- Server gửi lệnh xuống agent
- Agent thực thi lệnh firewall-drop
- Firewall (iptables) được cập nhật để chặn IP attacker

Kết quả:



- IP attacker bị chặn thành công
- Không thể tiếp tục kết nối đến hệ thống
- Kiểm tra bằng lệnh:

```
iptables -L
```

cho thấy rule chặn đã được áp dụng

```

nghianguyen on Sunday at 11:47 PM
MEM: 32.6% (2/7GB)
{ home } sudo iptables -L -n
Chain INPUT (policy ACCEPT)
target prot opt source destination
DROP 0 -- 192.168.144.1 0.0.0.0/0

Chain FORWARD (policy ACCEPT)
target prot opt source destination
DROP 0 -- 192.168.144.1 0.0.0.0/0

Chain OUTPUT (policy ACCEPT)
target prot opt source destination

nghianguyen on Sunday at 11:47 PM
MEM: 32.61% (2/7GB)
{ home }
  
```

Log của quá trình này được ghi nhận tại: `/var/ossec/logs/active-responses.log`

Đánh giá:

Cơ chế Active Response hoạt động nhanh và hiệu quả, gần như theo thời gian thực. Điều này giúp giảm thiểu đáng kể tác động của tấn công mà không cần can thiệp thủ công.

4.2.4 Tổng hợp đánh giá kết quả

Qua quá trình thực thi ba kịch bản kiểm thử, hệ thống giám sát an ninh sử dụng Wazuh đã thể hiện khả năng hoạt động ổn định và hiệu quả trong việc phát hiện cũng như phản ứng trước các hành vi tấn công phổ biến.

Trước hết, về **khả năng phát hiện (Detection)**, hệ thống đã nhận diện chính xác các hành vi đáng ngờ như tấn công brute force và thay đổi file hệ thống. Các rule mặc định của Wazuh hoạt động hiệu quả, cho phép phát hiện các pattern tấn công mà không cần xây dựng rule tùy chỉnh. Đồng thời, mức độ cảnh báo (alert level) được phân loại rõ ràng, giúp dễ dàng xác định mức độ nghiêm trọng của sự kiện.

Về **khả năng giám sát tính toàn vẹn (Integrity Monitoring)**, module FIM cho thấy hiệu quả cao khi phát hiện gần như ngay lập tức các thay đổi trên các file quan trọng. Thông tin chi tiết như đường dẫn file, thời gian thay đổi, giá trị hash trước và sau, cũng như nội dung diff giúp hỗ trợ quá trình phân tích sự cố một cách chính xác và nhanh chóng.

Đối với **khả năng phản ứng (Response)**, cơ chế Active Response hoạt động đúng như kỳ vọng. Hệ thống có thể tự động thực thi các hành động phòng thủ như chặn địa chỉ IP tấn công thông qua firewall ngay sau khi phát hiện hành vi nguy hiểm. Thời gian phản ứng gần như theo thời gian thực, góp phần giảm thiểu đáng kể tác động của cuộc tấn công.

4.3 Đánh giá hệ thống

Để đánh giá hiệu quả hoạt động của hệ thống giám sát an ninh sử dụng Wazuh, một số chỉ số quan trọng (metrics) được sử dụng bao gồm: tỷ lệ cảnh báo sai (False Positive), số lượng cảnh báo (Alert Volume) và thời gian phát hiện (Detection Time). Các chỉ số này giúp phản ánh mức độ chính xác, hiệu suất và khả năng phản ứng của hệ thống trong môi trường thực tế.

4.3.1 Phân tích chỉ số (Metrics)**a. Tỷ lệ False Positive**

Tỷ lệ False Positive thể hiện số lượng cảnh báo sai – tức là các cảnh báo được sinh ra nhưng không tương ứng với hành vi tấn công thực tế. Trong quá trình kiểm thử với các kịch bản brute force và thay đổi file, hệ thống Wazuh cho thấy tỷ lệ False Positive ở mức thấp.

Cụ thể:

- Các cảnh báo brute force chỉ được kích hoạt khi số lần đăng nhập thất bại vượt ngưỡng xác định
- Các thay đổi file được xác nhận dựa trên checksum và diff nội dung

Điều này cho thấy các rule mặc định của Wazuh có độ chính xác cao, hạn chế việc sinh cảnh báo không cần thiết. Đây là yếu tố quan trọng trong môi trường SOC, giúp giảm tải cho nhà phân tích và tránh tình trạng “alert fatigue” (quá tải cảnh báo).

b. Số lượng cảnh báo (Alert Volume)

Trong quá trình thực nghiệm, số lượng alert sinh ra tập trung chủ yếu vào các thời điểm xảy ra tấn công hoặc thay đổi hệ thống. Khi không có hành vi bất thường, hệ thống hầu như không sinh alert do đã được cấu hình chỉ ghi nhận các sự kiện quan trọng.

Đặc điểm chính:

- Alert tăng đột biến khi xảy ra brute force
- Alert FIM xuất hiện ngay khi có thay đổi file
- Không có alert dư thừa trong trạng thái bình thường

Điều này cho thấy hệ thống có khả năng **lọc nhiễu tốt** và tập trung vào các sự kiện có giá trị phân tích cao, giúp tối ưu hóa hiệu suất giám sát.

4.3.2 Đánh giá thời gian đáp ứng (Detection Time)

Thời gian phát hiện (Detection Time) là khoảng thời gian từ khi hành vi tấn công xảy ra đến khi hệ thống sinh cảnh báo hoặc thực hiện phản ứng.

Kết quả kiểm thử cho thấy:

- Đối với tấn công brute force: hệ thống phát hiện sau vài giây khi số lần đăng nhập thất bại đạt ngưỡng
- Đối với FIM: phát hiện gần như tức thời khi file bị thay đổi (realtime monitoring)
- Đối với Active Response: hành động chặn IP được thực thi ngay sau khi rule được kích hoạt

Nhìn chung, thời gian phát hiện và phản ứng của hệ thống đạt mức **gần realtime**, đáp ứng tốt yêu cầu của một hệ thống giám sát an ninh hiện đại.

4.3.3 Đánh giá tổng thể

Từ các chỉ số trên, có thể nhận thấy hệ thống Wazuh đáp ứng tốt các tiêu chí quan trọng:

- **Độ chính xác cao** (False Positive thấp)
- **Hiệu suất ổn định** (Alert hợp lý, không dư thừa)
- **Phản ứng nhanh** (Detection Time thấp)

Tuy nhiên, trong môi trường thực tế, hệ thống cần được tinh chỉnh thêm các rule và ngưỡng cảnh báo để phù hợp với đặc thù từng hệ thống, đồng thời kết hợp với các nguồn dữ liệu bổ sung nhằm nâng cao khả năng phát hiện các mối đe dọa phức tạp.

5 Kết luận và hướng phát triển

Sau quá trình nghiên cứu, phân tích, thiết kế và triển khai hệ thống giám sát an ninh sử dụng Wazuh, đề tài đã xây dựng được một mô hình SOC thu nhỏ trong môi trường thử nghiệm. Hệ thống có khả năng thu thập log từ các máy agent, phân tích sự kiện bảo mật, phát hiện hành vi bất thường và hỗ trợ phản ứng tự động trước một số tình huống tấn công phổ biến.

5.1 Kết quả đạt được

Trong quá trình thực hiện, đề tài đã đạt được một số kết quả chính như sau:

- Xây dựng thành công mô hình SOC thu nhỏ trong môi trường Lab với các thành phần chính gồm Wazuh Server, Linux Agent, Windows Agent và Kali Linux phục vụ kiểm thử.
- Triển khai được cơ chế thu thập log tập trung từ các agent về Wazuh Server thông qua giao thức TCP trên cổng 1514, đảm bảo dữ liệu log được gửi về hệ thống trung tâm để phân tích.
- Hệ thống phát hiện thành công hành vi tấn công Brute Force SSH/RDP thông qua việc phân tích các log đăng nhập thất bại liên tiếp. Cảnh báo được sinh ra với mức độ nghiêm trọng cao và có ánh xạ với kỹ thuật MITRE ATT&CK T1110 – Brute Force.

Nhìn chung, hệ thống đã đáp ứng được mục tiêu ban đầu là xây dựng một mô hình giám sát an ninh tập trung có khả năng phát hiện, phân tích và phản ứng với các sự cố bảo mật cơ bản trên host.

5.2 Hạn chế

Mặc dù hệ thống đã đáp ứng được các yêu cầu cơ bản của một mô hình SOC thu nhỏ, đề tài vẫn còn tồn tại một số hạn chế nhất định:

- Hệ thống mới chỉ được triển khai trong môi trường Lab, chưa được kiểm chứng trong môi trường doanh nghiệp thực tế với số lượng lớn thiết bị, người dùng và lưu lượng log phức tạp.
- Phạm vi giám sát chủ yếu tập trung vào host thông qua Windows Agent và Linux Agent, chưa tích hợp log từ các thiết bị mạng vật lý như firewall, router, switch, IDS/IPS hoặc hệ thống VPN.
- Các kịch bản kiểm thử còn ở mức cơ bản, bao gồm Brute Force, thay đổi file hệ thống và Active Response. Hệ thống chưa được kiểm thử với các chuỗi tấn công phức tạp hơn như lateral movement, privilege escalation nâng cao, command and control hoặc data exfiltration.

Những hạn chế trên cho thấy hệ thống hiện tại phù hợp với mục tiêu nghiên cứu, học tập và thử nghiệm. Tuy nhiên, để có thể ứng dụng trong môi trường thực tế, hệ thống cần được mở rộng thêm về nguồn log, rule phát hiện, quy trình vận hành và khả năng tự động hóa phản ứng.

5.3 Hướng phát triển

Trong tương lai, hệ thống có thể được phát triển theo các hướng sau:

- Mở rộng phạm vi giám sát bằng cách tích hợp thêm log từ các thiết bị mạng như firewall, router, switch, IDS/IPS, VPN Gateway và hệ thống Web Server. Điều này giúp hệ thống có cái nhìn toàn diện hơn về hoạt động an ninh trong toàn bộ hạ tầng.
- Tích hợp thêm nguồn Threat Intelligence để đối chiếu các sự kiện bảo mật với danh sách IP độc hại, domain độc hại, mã hash của malware và các chỉ dấu tấn công đã được công bố. Việc này giúp nâng cao độ chính xác trong quá trình phát hiện mối đe dọa.
- Xây dựng thêm các rule tùy chỉnh cho Wazuh nhằm phát hiện các hành vi tấn công phức tạp hơn như tạo tài khoản trái phép, thay đổi quyền quản trị, leo thang đặc quyền, thực thi lệnh bất thường, thay đổi registry trên Windows hoặc dấu hiệu persistence.

Với các hướng phát triển trên, mô hình SOC sử dụng Wazuh có thể tiếp tục được hoàn thiện để tiến gần hơn đến một hệ thống giám sát an ninh thực tế, có khả năng phát hiện, phân tích và phản ứng hiệu quả trước các mối đe dọa ngày càng phức tạp.

6 Nguồn dữ liệu và nguồn code

Trong quá trình thực hiện đề tài, hệ thống sử dụng nhiều nguồn dữ liệu khác nhau để phục vụ cho việc giám sát, phát hiện và phản ứng sự cố an ninh. Bên cạnh đó, các đoạn cấu hình và mã lệnh được sử dụng trong quá trình triển khai đóng vai trò quan trọng trong việc hiện thực hóa mô hình SOC thu nhỏ sử dụng Wazuh.

6.1 Nguồn code và cấu hình

Nguồn code trong đề tài chủ yếu bao gồm các file cấu hình Wazuh Manager, cấu hình Wazuh Agent và các lệnh kiểm thử được sử dụng trong môi trường Lab. Các thành phần này giúp hiện thực hóa mô hình giám sát, phát hiện và phản ứng sự cố.

Table 3: Các nguồn code và cấu hình sử dụng trong đề tài

Nguồn code / cấu hình	Vị trí / Thành phần	Vai trò
Cấu hình Wazuh Manager	single-node/config/wazuh_cluster/wazuh-manager.conf	Cấu hình wazuh manager, bao gồm global settings, agent registration, ruleset, vulnerability detector và active response.
Cấu hình Agent	ossec.conf trên máy agent	Cấu hình kết nối agent đến server, thu thập log, FIM, Rootcheck, SCA, Syscollector và Active Response.
Cấu hình FIM	Thẻ <syscheck>	Giám sát thay đổi file hệ thống, kiểm tra checksum, phát hiện file bị thêm, sửa hoặc xóa.
Cấu hình Rootcheck	Thẻ <rootcheck>	Phát hiện dấu hiệu rootkit, trojan, tiến trình bất thường và cổng mạng đáng ngờ.
Cấu hình Syscollector	Thẻ <wodle name="syscollector">	Thu thập thông tin inventory của hệ thống như phần cứng, hệ điều hành, package, port và process.
Cấu hình Vulnerability Detection	Thẻ <vulnerability-detector>	Đối chiếu thông tin phần mềm với cơ sở dữ liệu lỗ hổng để phát hiện CVE.
Cấu hình Active Response	Thẻ <active-response> và <command>	Kích hoạt phản ứng tự động khi rule phù hợp được phát hiện, ví dụ chặn IP attacker bằng firewall-drop.
Kịch bản kiểm thử Brute Force	Máy Kali Linux	Mô phỏng hành vi đăng nhập thất bại liên tiếp vào dịch vụ SSH/RDP để kiểm tra khả năng phát hiện của Wazuh.
Kịch bản kiểm thử FIM	Máy Linux Agent	Thay đổi file hệ thống quan trọng như /etc/passwd để kiểm tra khả năng phát hiện thay đổi file.
Kịch bản kiểm thử Active Response	Wazuh Server và Agent	Kiểm tra khả năng tự động chặn IP attacker sau khi phát hiện hành vi tấn công.

6.2 Vai trò của nguồn dữ liệu và nguồn code trong hệ thống

Nguồn dữ liệu và nguồn code có vai trò bổ trợ lẫn nhau trong quá trình triển khai hệ thống SOC thu nhỏ. Nguồn dữ liệu cung cấp thông tin đầu vào để hệ thống phân tích, trong khi nguồn code và cấu hình quyết định cách hệ thống thu thập, xử lý, phát hiện và phản ứng với các sự kiện bảo mật.

Cụ thể, các log xác thực giúp phát hiện tấn công Brute Force; dữ liệu FIM giúp phát hiện thay đổi file hệ thống; dữ liệu Syscollector và Vulnerability Detection hỗ trợ phát hiện lỗ hổng; trong khi cấu hình Active Response cho phép hệ thống thực hiện hành động phòng thủ tự động khi phát hiện hành vi nguy hiểm.



Nhờ sự kết hợp giữa các nguồn dữ liệu và cấu hình trên, hệ thống có thể đáp ứng các yêu cầu cơ bản của một mô hình SOC, bao gồm giám sát tập trung, phát hiện sự kiện bất thường, hiển thị cảnh báo và phản ứng tự động trong một số tình huống nhất định.

7 Tài liệu tham khảo

Các tài liệu tham khảo được sử dụng trong báo cáo bao gồm tài liệu chính thức của Wazuh, MITRE ATT&CK, NIST và một số tài liệu liên quan đến hệ điều hành, công cụ kiểm thử và mô hình giám sát an ninh.

References

- [1] Wazuh Documentation, *Wazuh Documentation – User Manual and Capabilities*. Available at: <https://documentation.wazuh.com/current/index.html>
- [2] Wazuh Documentation, *File Integrity Monitoring*. Available at: <https://documentation.wazuh.com/current/user-manual/capabilities/file-integrity/index.html>
- [3] Wazuh Documentation, *Advanced settings – File Integrity Monitoring*. Available at: <https://documentation.wazuh.com/current/user-manual/capabilities/file-integrity/advanced-settings.html>
- [4] Wazuh Documentation, *Wazuh Agent – User Manual*. Available at: <https://documentation.wazuh.com/current/user-manual/agent/index.html>
- [5] Wazuh Documentation, *Wazuh Agent Enrollment*. Available at: <https://documentation.wazuh.com/current/user-manual/agent/agent-enrollment/index.html>
- [6] Wazuh Documentation, *How it works – Vulnerability Detection*. Available at: <https://documentation.wazuh.com/current/user-manual/capabilities/vulnerability-detection/how-it-works.html>
- [7] Wazuh Documentation, *User Manual*. Available at: <https://documentation.wazuh.com/current/user-manual/index.html>
- [8] MITRE ATT&CK, *Technique T1110 – Brute Force*. Available at: <https://attack.mitre.org/techniques/T1110/>
- [9] National Institute of Standards and Technology, *NIST Special Publication 800-61 Revision 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management*. Available at: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
- [10] National Institute of Standards and Technology, *The NIST Cybersecurity Framework 2.0*. Available at: <https://www.nist.gov/cyberframework>
- [11] Ubuntu Documentation, *Ubuntu Server Documentation*. Available at: <https://documentation.ubuntu.com/server/>
- [12] Kali Linux Documentation, *Kali Linux Documentation*. Available at: <https://www.kali.org/docs/>
- [13] THC Hydra Project, *Hydra – Network Logon Cracker*. Available at: <https://github.com/vanhauser-thc/thc-hydra>
- [14] Docker Documentation, *Docker Documentation*. Available at: <https://docs.docker.com/>